SUNHAVEN / UNIFIED 8.0

Operating guide & release handover

Complete original archive + expanded local governance portal

545 original files preserved • 145 automated tests passing

24 September 2026

Includes local access packages, temporary incident response, service and agent identity governance, original SITAS and SAIF adapters, research references and a future extension roadmap.

Laboratory release. Live tenant integration, public deployment and visual browser acceptance remain unverified.

Sunhaven Unified 8.0 — operating and technical guide

1. Purpose

Sunhaven has a high-turnover workforce, agency contracts and sensitive resident-access boundaries. This laboratory demonstrates how to validate access, approve it, enforce expiry, remove it, investigate concerns and retain evidence. All care and workforce examples are fictional. It is an educational IAM prototype, not an electronic clinical record product.

2. Package architecture

run.py starts the portal from portal/. Its HTTP and WSGI adapters share route handlers. SQLite stores employees, roles, resident assignments, sessions, requests, reviews, incidents, service identities and integration-run results. The original project is retained under original/ with a 545-file hash manifest.

New routes: /hub, /catalog, /catalog/resource/<package>, /services, /incidents, /policy-lab, /integrations. State-changing forms post to explicit /console/<action> routes protected by the existing CSRF middleware. Services recheck roles and worker state inside SQLite transactions; rendering a button is never the authorization decision.

enterprise.py provides local package, service-identity and incident rules. enterprise_ui.py renders their views. integrations.py invokes a fixed integration_worker.py subprocess using a 20-second timeout and no shell. The worker imports the original SITAS/SAIF modules. It accepts bounded form values and a portal workforce snapshot; it has no Graph-dispatch branch.

SITAS receives a temporary CSV generated from current portal workers and the original mapping files. It reports missing role mappings, including IAMOperator, rather than inventing them. The original data and scripts are not rewritten. The original Flask and new portal databases remain separate.

3. Launch and roles

Run python run.py from the extracted root and visit http://127.0.0.1:8000. Local mode has an identity selector, not password authentication. Select Ivy Chen (SC1005, IAMOperator), Daniel Lee (SC1002, Manager), Omar Rahman (SC1004, Auditor), Sarah Khan (SC1001, Nurse) or Mia Patel (SC1003, CareWorker).

Care workers and agency workers see assigned residents, their own requests and reminders, plus the access catalogue. Nurses receive their configured clinical scope. Managers review requests and governance, auditors have read views, and operators administer local identities. Manager scope is organisation-wide in this prototype. New incident changes additionally require the temporary responder grant; this does not remove or replace the existing operator permissions on older administration pages.

The first start creates 42 workers, 30 residents and 35 notes with dates relative to startup. A deliberately expired active agency identity demonstrates a finding and is denied login. Portal data is in portal/data/sunhaven.db unless SUNHAVEN_DB_PATH overrides it.

4. Existing workforce and care features

Dashboard: filter the facility chart, use statistic links, search permitted records and switch light/dark theme. Employees: create a Joiner after dry-run validation. Worker profiles: inspect identity state, notes and assignments; run Leaver to disable mock access, remove roles/assignments, revoke sessions and block future requests.

Mover: submit an access request; another authorised identity decides; the operator executes a fresh approved request with matching worker snapshot. The existing seven-day approval rule and one-use execution still apply. A direct Mover apply form is blocked. Resident access checks happen on the server for both navigation and direct URLs.

Reviews: record Retain, Change, Remove or Temporary Exception with a reason. Resolve remediation tasks with evidence. Onboarding records four checklist steps; ticking them does not grant access. Notifications show role-scoped reminders and personal read state. Notes remain synthetic workforce handovers. CSV exports neutralise spreadsheet formulas and reports export aggregate PDF counts.

5. Agency automation and security evidence

Automation previews expired agency workers and upcoming contract end dates. Ivy can submit a reason and execute the current preview. A stale preview is rejected. The local transaction suspends targets, disables simulated cloud access, removes roles/assignments, revokes sessions, applies local blocks and records run/audit history. A repeated run without targets is a no-op.

From portal/, python manage.py expire-agency previews. An explicit --apply --actor-id SC1005 --reason "Reviewed synthetic contract expiry" is supported only in development/mock mode. This is an on-demand run; no unattended cloud scheduler is installed.

Security assurance shows the existing compact threat/control model, recent ingested MFA findings and ledger checks. python -m security_workstream.demo --output demo-evidence creates synthetic evidence. The MFA analyzer accepts sanitized event JSON through python -m security_workstream.analyze_file events.json --output findings.json --ingest-findings. Its rules cover denial bursts, prompt bursts and denial-to-success patterns in a five-minute window; no real authentication telemetry is connected.

6. Access catalogue and temporary response

Care learning: eligible frontline, nursing, management and operator roles; valid for 24 hours. Quality review: Nurse, Manager, Auditor or IAMOperator; valid for four hours; exposes aggregate fictional workforce metrics. Temporary incident responder: Manager or IAMOperator; valid for one hour; permits incident creation and transitions. Durations begin at approval.

Demonstration: select Ivy, request Temporary incident responder with a business reason; sign out and select Daniel; approve Ivy's pending request with evidence; sign back in as Ivy and open the approved workspace. No user can approve their own request. Duplicate pending/active requests are rejected. Requests older than seven days cannot be approved. Changed roles, facility or end date invalidate the snapshot. Inactive/blocked/expired agency identities cannot use grants.

Quality review and incident response are deliberately conflicting packages to demonstrate separation of duties. Revoke the active conflicting grant before approving the other. Expiry is checked on every resource request and incident write, so it does not depend on a cleanup job. These packages do not grant Microsoft roles or additional resident access.

7. Incident response

With an active responder package, open an incident with a title, severity, responsible manager/operator and evidence. Progress through Open, Investigating, Contained and Resolved. Skipping a state is rejected. Each update records evidence in the audit trail; the case displays the most recent evidence. Resolution does not automatically disable a person or call an external service. Use the separate authorised lifecycle workflow when appropriate.

Managers/operators without a responder package and auditors may read governance views but cannot modify incidents. When the grant expires or is revoked, incident changes stop immediately.

8. Service and agent identities

Ivy can register a synthetic Service or Agent, choose an active manager/operator owner, assign local scopes and select a lifetime of 1–90 days. Supported scopes: metrics.read, training.read and incidents.summarize. No wildcard, directory-write or patient-data scope is accepted.

Evaluate an action to see ALLOW or DENY based on identity status, expiry, owner eligibility and the requested scope. Disable stops subsequent evaluations from allowing the identity. The audit records registration, evaluation and disable. This is a governance registry and policy demonstration; it does not issue credentials, execute an AI model or create Microsoft Agent ID objects.

9. Conditional access lab

Choose declared sign-in risk, device state, authentication method and active status. The sample policy blocks inactive identities, high risk, unmanaged devices and methods other than Passkey. Each result explains the reason. This is a what-if exercise: no device attestation, passkey registration or live risk signal is implemented, and selecting Passkey is not proof of authentication.

10. Original module integration

Integrations lets managers/operators run the original SITAS engine, including all six scenarios and a workforce-derived leaver comparison. Results persist and are visible to auditors. Before/after results are controlled simulations, not evidence of actual cloud enforcement. The current original-config-to-portal role gap is visible in mapping findings.

SAIF uses the original approved-agency configuration. Example: worker EXT-DEMO-01, fictional name, demo@sydneycare.example, AG001. An approved domain/agency produces an invitation payload preview; AG003 is blocked. No invitation is sent. Domain consistency alone does not prove ownership. The original Graph invitation and identity-handover workflow remains under original/ and requires its own lab setup.

To run original SITAS independently: python run.py sitas. For the original Flask/Entra project, follow original/README.md, install app/requirements.txt in a virtual environment, configure your own tenant/app/redirect locally, install Graph PowerShell, and run Flask from original/app. Graph mutations still require the scripts' original Apply and exact approval gates. No tenant action was executed while building v7.

11. Data safety, backup and reset

The SQLite database and its .ledger.key/.ledger.head sidecars form one local evidence set. Stop all writers, then from portal/ run python manage.py backup backups/sunhaven.db. Preserve the database and sidecars together. For restore, stop the application, copy the known-good set into the configured data location and verify the ledger before accepting more writes. A restore drill against a separate path is recommended before relying on backups.

python reset_demo.py --confirm-reset from portal/ discards demo data and its ledger. Export any evidence first. Do not place real clinical data, secrets or tokens in notes or integration input. Original screenshots may contain lab identifiers; the bundle is intended for private assessment and lab use.

12. Deployment and optimization

The dependency-free server binds loopback by default. A root Dockerfile builds the WSGI portal with original modules present; compose.yaml publishes only localhost:8000. Container and public deployment were not tested here. Existing portal deployment examples are historical and may omit the sibling original folder; use the root Dockerfile for the integrated release.

New indexes cover active package lookup, pending-request uniqueness, incident state, integration history, audit time, session expiry and employee expiry. New list views are bounded to the latest 100 records, integration history to five runs, and subprocess execution to 20 seconds. These changes control query/output work; no throughput or production scalability claim is made.

A real service still needs verified Entra mapping, tenant integration and recovery tests, managed secrets, HTTPS, durable remote audit, threat monitoring, privacy approval, a production database strategy, accessibility/browser acceptance and operational ownership. The local HMAC chain cannot substitute for off-host immutable logging. Future work is in ROADMAP.md.

13. Version 8 — staff roster reconciliation

Open **Roster sync** as a manager or IAM operator. Paste fictional CSV with exactly employee_id,email,role,facility,status,end_date and no more than 100 rows / 32 KB. A populated two-row example appears in the form. Stage validates unique IDs, known statuses, ISO dates, current employee email and row shape. The preview records proposed actions without changing worker permissions. New worker IDs, changed role/facility and attempted reactivation create review findings only.

A different manager/operator must approve the staged plan with a reason. An IAM operator executes only an approved, still-current plan; the approver cannot execute their own decision. If a worker's identity, role, facility, contract date or current state changes in between, the import is rejected. Approved leaver rows disable the synthetic account, revoke roles/sessions/assignments and block the portal atomically. Approved agency date changes update local contract dates. Existing automation can then act on expired contracts. This CSV is a manually reviewed fictional HR input, not a connected HR authority, and makes no Graph writes.

14. Version 8 — quarterly access certification

Open **Quarterly reviews** as IAMOperator to start the current quarter; an existing campaign is reused. Active workers are snapshotted with role and facility and given a due date 14 days later. A different manager/operator records Retain or Remove with evidence. If role or facility changes after the snapshot, reconciliation is required first. Remove revokes active temporary access packages immediately and opens a high-priority task for the core role. It does not silently remove resident permissions; an authorised operator handles the core-role change through existing workflows.

cd portal && python scheduler.py previews the current quarter, overdue pending reviews and expired agency count. Run python scheduler.py --apply --actor SC1005 from a trusted local scheduler such as cron or Windows Task Scheduler to create the review once per quarter. This command intentionally previews expired agency access; the operator must still approve the actual shutdown in Automation. The scheduler is an entry point, not an always-running daemon.

15. Version 8 — portable audit handover

From portal/, run python audit_export.py evidence.ndjson --actor SC1004 as an auditor or IAMOperator. A failing ledger check stops the export. The output contains audit events in order, is written atomically with restricted local file permissions and returns a SHA-256 checksum; existing files are never overwritten. Store the file under your approved evidence retention process. This is a local verifiable handover, not a remote immutable archive or live SIEM feed.

Feature preservation and release matrix

Capability	Release 7 implementation	Status
Original Flask OIDC and care portal	original/app, unchanged	Preserved; own tenant required
Graph PowerShell JML, dry-run, approval, tenant checks, idempotence, readback	original/automation, unchanged	Preserved; no live revalidation
Original access review, policies and evidence	All 545 original files with SHA-256 manifest	Preserved and verified
Full SITAS graph/path/risk/control/reporting/adapter	Original engine + read-only portal bridge	Integrated; 66 original tests pass
SAIF validation, invitation, mapping, handover	Full original component; validator/preview bridge	Validation integrated; real B2B transport retained
SMFAA planning	original/services	Preserved documents
Working synthetic MFA analyzer	portal/security_workstream	Retained local implementation
Local JML, resident scope and notes	Existing portal services	Retained and tested
Reviews, tasks, policies, risks, compliance, onboarding	Existing portal modules	Retained and tested
Agency expiry, reminders, reports and ledger	Existing portal automation/evidence	Retained and tested
Access packages with independent decision, expiry and revocation	enterprise.py + protected resources	Implemented locally
Temporary incident response	Independently approved, 60-minute capability checked per write	Local; not Entra PIM
Separation of duties	Quality-review conflicts with incident-response	Local example
Service and agent governance	Owner, scope, lifetime, evaluation, disable	Local registry, no agent execution
Incident management	Open → Investigating → Contained → Resolved with evidence	Implemented locally
Conditional access, passkey and device what-if	Declared inputs and explanation	Simulator only
Live portal Graph writes	Blocked; original scripts available separately	Integration pending
Live agent credentials and device attestation	No production connector	Roadmap
Public deployment and enterprise certification	No verified deployment	Not claimed

Original and portal databases and role schemes require an explicitly validated connector before a single live service can be claimed.

Version 8 additions

Capability	Delivery	Status
HR roster reconciliation	CSV validation, independent approval, snapshot recheck, local leaver disable and agency date update	Implemented locally; HR connector pending
Quarterly certification	One campaign per quarter, independent decisions, package revocation and role remediation task	Implemented locally
Daily scheduled check	CLI preview and idempotent quarterly campaign creation via external scheduler	Implemented; no autonomous worker installed
Audit handover	Ledger-checked local NDJSON export with SHA-256 result	Implemented locally; remote archive pending

Research informing version 7

Official documentation consulted on 24 September 2026. Implementations are local educational equivalents, not Microsoft product functionality or licence entitlements. No future vendor release is predicted.

1. Microsoft Entra ID Governance:
https://learn.microsoft.com/en-us/entra/id-governance/identity-governance-overview

Informed request/approval, expiry and temporary access.

2. Secure governance practices:
https://learn.microsoft.com/en-us/entra/id-governance/best-practices-secure-id-governance

Informed limited duration and explicit role boundaries.

3. Authentication strengths:
https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-strengths

Informed the phishing-resistant authentication what-if exercise; actual enforcement needs an identity provider.

4. Microsoft Entra Agent ID: https://learn.microsoft.com/en-us/entra/agent-id/what-is-microsoft-entra-agent-id

Informed explicit nonhuman identity ownership and scoped governance. This registry does not create Entra objects.

5. Agent governance: https://learn.microsoft.com/en-us/entra/id-governance/agent-id-governance-overview

Informed owner lifecycle and expiry checks.

Pages may change. Recheck licences and rollout states before implementing tenant connectors. References explain design choices and do not certify this software.

Extension roadmap — proposed, not implemented

Version 8 now includes a reviewed CSV roster import, quarterly certification campaigns, an external scheduler command and local audit export. The items below describe their live integrations and other future extensions.

There is no fixed list of every possible future feature. These are useful extensions and the evidence required to claim completion.

Priority	Extension	Acceptance evidence
1	One live connector shared by portal and Graph scripts	Immutable-ID/role mappings, tenant checks, dry-run, approval, retry/partial-failure recovery and live readback
1	Real OIDC + MFA/passkeys	Tenant policy and allowed/denied sign-in evidence; never trust a form selection
1	SAIF invitation-to-role handover	Sponsor, redemption, identity binding, role approval and revocation tests
1	Remote audit and recovery	Off-host sink, retention, failure handling and observed restoration drill
2	Durable background job queue beyond the current cron command	Lease ownership, retries, idempotency, pause control, dead-letter queue and alerts
2	Live SCIM/HR connector beyond the reviewed CSV workflow	Validated schema, source-of-truth rules, reconciliation and replay-safe provisioning
2	Facility-scoped managers	Resource-level authorization matrix and cross-facility denial tests
2	Cross-system recurring reviews beyond the local quarterly campaigns	Membership snapshots, independent reviewers, escalation and remediation evidence
2	Device/risk feeds	Trusted attestation, missing-signal rules and fail-closed tests
3	Governed AI assistant	Read-only scope, ownership, evidence citations, injection tests and human change approval
3	Agent workload federation	Short-lived tokens, audience binding, secretless identity and revocation checks
3	Resilience and scale	Production database, worker isolation, load objectives and fault injection

Do not describe proposals as delivered. Define user need, security boundary, implementation, test and operating procedure for each addition.

Release test and validation record

Executed in the current Python 3.12 environment on 24 September 2026.

Check	Result	Evidence
Portal regression and new governance suite	66 passed	evidence/portal-tests.txt
Original SITAS pytest suite	66 passed	evidence/sitas-tests.txt
Original SAIF pytest suite	13 passed	evidence/saif-tests.txt
Actual local HTTP login, twelve routes and a staged roster approval flow	Passed	evidence/http-smoke-v8.json
Original archive SHA-256 comparison	All 545 files match	ORIGINAL_MANIFEST.json; python run.py verify-original
Visual browser preview	Not verified: service blocked localhost	No visual acceptance claim
Live Microsoft tenant / PowerShell actions	Not executed in this release	Original historical evidence retained separately
Container / public deployment	Not executed	Configuration supplied for further validation

New tests cover unauthorized direct POSTs, CSRF, self-approval, duplicates/replay, grant expiry, revocation, stale worker/request state, conflicting packages, expired agency workers, owner disablement, scope denial, identity expiry, kill switch, incident transition order, expired response privilege, policy input validation, XSS escaping, original SITAS current-worker integration and SAIF preview without invitation dispatch.

Tests use temporary synthetic databases; shipped portal data is created afresh on first run. Original SITAS and SAIF test counts are now reproduced locally, not merely copied from their historical evidence. The 14 original live core scenarios remain historical tenant evidence and were not counted as newly executed tests.

Version 8 update

The portal suite now has **66 passing tests**. New tests exercise staged leaver disablement and session revocation, separate approver/executor, stale roster rejection, duplicate and mismatched CSV input, approved agency dates, quarterly campaign idempotence, self-review denial, temporary-access revocation, core-role remediation, scheduler access control, audit export and web CSRF/role restrictions. Original SITAS **66** and original SAIF **13** still pass separately: **145 total automated tests**. Local browser visual acceptance, live Microsoft connection and Docker remain unverified.